Nexora IT Access Control Policy

Purpose, Least Privilege and Role Assignment

Policy Reference

Policy NX-SEC-002, version 2.0, effective 1 April 2025. Classification: Confidential - Security. Owner: Security Manager.

Role-Based Access

Access is granted through roles, never through individually assigned permissions. The standard roles are SUPER_ADMIN, HR_MANAGER, FINANCE_MANAGER, ENGINEERING_MANAGER, SECURITY_MANAGER and EMPLOYEE.

Least privilege: every user receives only the minimum access needed for their job and holds one primary role.

Role Assignment Approval

Role requests are raised as IT service desk tickets and approved by the user's manager and the data owner.

SUPER_ADMIN assignments require CISO approval and are limited to 2 holders.

Account Lifecycle: Onboarding and Offboarding

Onboarding

IT creates accounts one working day before the joining date. New joiners receive only the EMPLOYEE role. Additional roles are approved within 2 working days.

Transfers

When an employee changes department, access from the previous role is removed within 1 working day of the transfer.

Offboarding

Access is revoked within 4 hours of an employee's last working day.

For involuntary separations, access is revoked immediately when Human Resources notifies IT. Laptops are returned within 3 working days.

Access Reviews

User Access Reviews

Managers review standard user access quarterly, in January, April, July and October.

Privileged Account Reviews

Privileged accounts are reviewed monthly by the Security Manager. Each monthly review must be completed by the 10th day of the month.

Service Accounts and Findings

Service accounts are reviewed every 6 months, and every service account must have a named owner.

Access review findings are remediated within 5 working days.

Privileged Accounts and Access Revocation

Privileged Accounts

Administrators use separate accounts with the prefix adm-. Just-in-time elevation lasts at most 8 hours.

Two sealed break-glass accounts exist for emergencies. Any break-glass use triggers a SEV-2 security review.

Engineering Production Access

Engineering managers approve production access requests for their own teams.

Production database access is just-in-time and limited to 4 hours per request.

Access Revocation

Accounts inactive for 45 days are disabled automatically and deleted after 90 days.

Access is revoked immediately when an account compromise is suspected.

Audit Review Schedule

Audit Schedule

Security operations reviews access logs every week.

A quarterly access certification report is sent to the CISO.

An external IT audit takes place every January. Audit evidence is retained for 3 years.

Exceptions and Non-Compliance

Policy exceptions must be documented and approved by the CISO and are valid for at most 90 days.

Violations of this policy may lead to removal of access and disciplinary action.